MSI+BIT Security of Software and Systems

Exercise sheet 01 - Intro & ISM

Discussion on Monday, October 27 2025

PART 1: INTRODUCTION

Task 1: Match the Terminology

Match the terms with the correct definitions below.

Term	Definition Letter
1. Confidentiality	____
2. Integrity	____
3. Availability	____
4. Vulnerability	____
5. Threat	____
6. Attack	____
7. Risk	____

A. A flaw or weakness that can be exploited
B. Ensuring that information is accessible when needed
C. Ensuring data has not been modified without authorization
D. The potential for a negative event that may exploit a vulnerability
E. The likelihood and impact of a negative event
F. Protection against unauthorized access to data
G. A deliberate action taken to exploit a vulnerability

Task 2: Real-World Examples

Assign the correct CIA security goal to each of the following examples

Scenario	Security Goal(s) (C/I/A)
1. A hacker intercepts and reads unencrypted medical records in transit.	
2. A staff member accidentally deletes patient data in the Enterprise Resource Planning (ERP) system.	
3. A DDoS attack makes the company's e-commerce site unreachable.	
4. A backup system restores data to its original, unchanged form.	
5. An employee accesses customer records without authorization.	

Task 3: Mini-Case Scenario

Scenario:

MedSupply Global uses a cloud-based Customer Relationship Management (CRM) system. The company hasn't enforced strong password policies, and users often reuse passwords. One day, a hacker uses leaked credentials to log into a sales employee's account and downloads all customer records.

Questions

1. What is the asset at risk?
2. What is the vulnerability in this case?
3. What is the threat?
4. What is the attack?
5. What is the resulting risk?
6. Which CIA goals are violated?

Task 4: Protection Needs Estimation

Determine the protection need (Normal / High / Very High) for the following data types.

Data Type	Confidentiality Integrity Availability	Reasoning (brief)
1. Product Catalog (public website)		
2. Medical device order with patient name		
3. Internal audit report		
4. Customer Relationship Management System access logs		

Task 5: Security Controls

For each scenario, identify:

1. One appropriate security measure
2. The type of control it represents:
   - (P) Preventive – stops an incident from occurring
   - (D) Detective – identifies incidents as they happen or after
   - (C) Corrective – restores systems or mitigates damage

■

Scenario	Suggested Measure	Control Type
1. Employees might reuse weak passwords		
2. A hacker tries to access the network from outside		
3. A file server crashes and important documents are lost		
4. Someone tampers with log files to hide their actions		
5. Suspicious activity is noticed in user login patterns		

PART 2: INFORMATION SECURITY MANAGEMENT

Analyzing Fictional Company MedSupply Global GmbH

Assume the Company MedSupply Global GmbH wants to employ BSI Grundschutz.

MedSupply Global GmbH is an internationally operating company specializing in the distribution of medical devices. Headquartered in Germany, the company maintains regional offices and warehouses across Europe, North America, and Asia. MedSupply Global acts primarily as a reseller, partnering with certified manufacturers to provide cutting-edge medical equipment to healthcare institutions and private clients.

The main clientele includes hospitals, clinics, and specialized medical centers, which rely on timely and secure delivery of diagnostic and therapeutic devices. In addition to institutional clients, a selected range of products (e.g., blood pressure monitors, glucose meters, and mobile ECG devices) is available for individual customers with chronic health conditions through an online shop.

Key business processes include:

- Procurement and supplier management
- Logistics and international shipping
- Customer support and technical consulting
- Online sales and e-commerce operations

MedSupply Global relies on a centralized Enterprise Resource Planning (ERP) system for inventory, sales, and supplier relations, with integration to a cloud-based Customer Relationship Management (CRM) and e-commerce platform. Further, its employees use workstations either from the office or remotely via a Virtual Private Network (VPN).

Feel free to be creative for the following tasks if the necessary information is not directly given in the scenario description above.

Task 1

Define the scope, assets and the structure.

- Choose a reasonable scope (e.g. e-commerce platform)
- List the most important assets that are in scope.
- List the relevant components: IT systems, business processes, applications, network topology plan, rooms and buildings

Task 2

Determine the confidentiality, integrity, and availability needs of key components.

- Choose 3–4 assets or components.
- Assign protection requirements for each security goal (Normal / High / Very High).
- Apply inherence rules where applicable.

Task 3

Assign BSI building blocks (modules/”Bausteine”) to the selected components.

- Match each component to its relevant BSI building block (e.g., APP.4.2 for ERP).
- Use the IT-Grundschutz-Kompendium (online).

Task 4

Identify one potential risk and assess whether standard protection is sufficient.

- Pick one risk (e.g., cloud CRM data leak).
- Use a risk matrix to estimate risk (likelihood × impact).
- Decide whether an additional measure is needed.